第 1 章 绪　论

本章学习要点：

- 掌握信息安全的基本概念和基本服务；
- 了解信息安全面临的主要威胁；
- 了解信息安全体系结构，掌握相关概念和模型。

1.1　信息安全概述

信息安全是全社会都非常关心的重要问题。从国家层面来说，网络安全是国家战略的重要组成部分。早在 2014 年，习近平总书记就指出“没有网络安全就没有国家安全，没有信息化就没有现代化”，并强调“网络安全和信息化是一体之两翼、驱动之双轮，必须统一谋划、统一部署、统一推进、统一实施”。近年来有关信息安全的法律相继出台（表 1.1），标志着我国信息安全治理迈向全面法治化。

表 1.1　信息安全相关法律

法律名称	实施时间	内容简述
《中华人民共和国电子签名法》	2005 年 4 月 1 日	规范电子签名行为，确立电子签名的法律效力，维护有关各方的合法权益
《中华人民共和国网络安全法》	2017 年 6 月 1 日	提出制定网络安全战略，明确网络空间治理目标，要求相关企业、机构和单位保障网络安全，保障国家、公共利益，制定和完善相关技术标准，推进网络安全监督
《中华人民共和国密码法》	2020 年 1 月 1 日	规范密码的应用和管理、密码的安全性和使用要求、安全管理制度等，规定了相应的法律责任
《中华人民共和国数据安全法》	2021 年 9 月 1 日	体现总体国家安全观的立法目标，聚焦数据安全领域的突出问题，确立数据分类分级管理，建立数据安全风险评估、监测预警、应急处置、数据安全审查等基本制度，并明确相关主体的数据安全保护义务
《中华人民共和国个人信息保护法》	2021 年 11 月 1 日	制定了个人信息的保护对象、应用、权利、责任等方面的规定，明确了收集、存储、使用、处理、传输个人信息的法律要求，加强个人信息的安全保护和真实性保护

相关网络安全法律法规的实施，标志着我国网络安全管理的进一步规范化和严格化，是保障国家网络安全的重要法律基础和制度保障。当前，我国网络安全事业有了积极的变化和提升，网络安全建设和管理工作稳步推进，网络安全法律体系不断完善，网络安全意识和能力明显提升，各种网络安全威胁得到了有效防范和遏制。

2023 年 3 月中国互联网络信息中心（China Internet Network Information Center，CNNIC）发布的第 51 次《中国互联网络发展状况统计报告》显示：截至 2022 年 12 月，我国网

民规模达10.67亿，较2021年12月增长3549万，互联网普及率达75.6%；我国移动网络的终端连接总数已达35.28亿户，移动物联网连接数达到18.45亿户，万物互联基础不断夯实。这些数据说明网络对社会的影响越来越大，与此同时，在日常工作和生活中，人们也越来越依赖计算机网络，越来越多地使用各种信息系统来处理敏感数据。以开放式、分布式、异构性等为主要特征的网络信息系统承载着巨大的数据和信息资源，提供着难以估量的网上信息服务、软件应用和业务服务，网络信息系统的一次故障或事故往往会造成巨大的影响，甚至是灾难。

从当前网络应用软件系统的发展趋势来看，应用需求愈来愈多，复杂度愈来愈高，可用性要求愈来愈强，日趋庞大的软件系统却愈来愈脆弱。特别是近年来，随着云计算、大数据、物联网、人工智能和区块链等新型信息技术的发展，共享的网络计算环境已经演化成为边界模糊、系统开放的公用化计算环境，这对信息安全理论与技术提出了新的要求和新的挑战。

1.1.1 信息与信息安全

信息安全指保护计算机系统、网络系统、传输的信息和存储的数据免受未经授权的访问、使用，避免被泄露、破坏、篡改和干扰等威胁。简单来说，信息安全是保障信息系统中信息的保密性、完整性和可用性的一种方式。要理解什么是信息安全，需要先了解什么是信息，什么是数据。

数据(data)是人类日常生活中经常用到的一个概念。比如，通常我们会说，让事实说话，让数据说话，数据就是事实。所以一般认为：数据是用来反映客观世界而记录下来的可以鉴别的物理符号。数据具有客观性和可鉴别性，数据并不只是数字，所有用来描述客观事实的语言、文字、图画和模型等都是数据。在现实生活中，随着生产和生活的进行，数据随时随地不断产生。例如，我们上网时产生的浏览记录，手机的通话记录和短信、微信、QQ等即时通信中的记录，支付宝中的支付记录，电子商务网上交易记录，每只股票价格的变化记录，医院里病人的电子病历，学校里学生的电子档案等，这些都是数据。随着计算机应用的普及，特别是智能终端的应用，计算无处不在、网络无处不在、数据无处不在、软件无处不在。近年来，随着存储设备价格下降和云计算的发展，各行各业积累的数据越来越多，特别是大数据(big data)技术的发展，数据资源的价值日益突显。2022年12月发布的《中共中央 国务院关于构建数据基础制度更好发挥数据要素作用的意见》中，明确“数据作为新型生产要素，是数字化、网络化、智能化的基础，已快速融入生产、分配、流通、消费和社会服务管理等各环节，深刻改变着生产方式、生活方式和社会治理方式。”数据的重要性可见一斑。

信息(information)这一概念已在社会各个领域得到广泛应用。关于信息的定义有多种说法，通常人们认为：信息是有一定含义的数据，是加工处理后的数据，是对决策者有用的数据。信息是人们关心的事情的情况。例如：对于生产或销售某产品的企业来说，该产品的市场需求和销售利润的变化是重要信息；对于购买此产品的消费者来说，产品的性能及市场价格是重要信息；计划出国学习的人，关心出国信息；准备找工作的人，关心就业信息；炒股票的人，关心股市信息。总之，信息是当今社会最重要的组成要素之一，美国著名未来学家托夫勒曾说：“谁掌握了信息，控制了网络，谁将拥有整个世界。”数据处理就是将数据转化为信息的过程，信息技术也都是围绕着数据收集、存储、传输、加工处理等方面开展应用的。

随着全球范围内数据泄露、黑客攻击等安全事件不断出现，信息安全(information security)的重要性越发被人们重视，很多企业都将信息安全工作提到了战略性的高度。然而，企业信息安全究竟要做什么？要关注哪些方面？如何来落实？这些问题是企业管理者要面对的重要问题。

信息安全通常包括网络安全、数据安全、应用程序安全、身份认证、访问控制、安全管理、物理安全等，只有通过全面的策略和实施方案，综合运用技术、管理和人员培训等多种手段，才能保证信息和数据的安全性，确保信息系统的稳定和有效运行。比如，密码保护、用户权限管理和数据备份等都需要有全面的策略和实施方案。

在信息化时代，保障信息安全越来越重要。一旦信息泄露或被篡改，可能会给个人或组织带来不可逆转的损失。因此，在信息系统设计和实施过程中，必须重视信息安全问题，并采取相应的安全技术和措施来加强信息安全保障。

1.1.2 信息安全的基本目标

信息安全的目标就是保证计算机系统正常运行，具体表现为三个基本属性或基本目标：保密性(confidentiality)、完整性(integrity)和可用性(availability)，即信息技术评估标准中所述的三要素——CIA。

1. 保密性

确保信息在存储、使用、传输过程中不会泄露给非授权用户或实体。保证信息只能被授权访问者所获取，确保信息不被未授权的人或系统所获取。保密性也可以适用于数据在传输过程中的保护，以防止数据被截获或窃听。

2. 完整性

确保信息在存储、使用、传输过程中不会被非授权用户篡改，同时还要防止授权用户对系统及信息进行不恰当篡改，保持信息内、外部表示的一致性。保证数据和信息能够准确地反映其真实和完整的状态。完整性还可以保证数据和信息采集的过程中没有丢失或受到损坏。

3. 可用性

确保授权用户或实体对信息及资源的正常使用不会被异常拒绝，允许其可靠而及时地访问信息及资源。保证信息系统和服务能够在需要时正常可用，访问者能够合法地使用系统中的信息和数据，防止由于主观或客观因素导致系统停机或无法访问。可用性与性能和容错等因素密切相关。

这三个目标是相互关联、相互作用的，它们共同构成了信息安全的基本框架，任何一个目标的丧失都可能导致信息安全威胁和风险的发生，因此，信息安全不能单纯地考虑某一个方面的安全问题，而必须全面、系统地考虑整个信息系统的安全性。同时，信息安全的实现还具有综合性、前瞻性、科学性、合法性等多种特性，涉及技术、管理、人才和法律等方面。

因此，信息安全的基本目标不仅仅是为了解决现有的信息安全问题，更是为了应对未来的信息安全挑战，确保信息系统的安全、可靠、稳定和高效，保障信息资产的利用和价值的最大化，维护信息社会的稳定和发展。

1.1.3 信息安全现状分析

那么为什么会产生信息安全问题？其根源又是什么呢？

当前，信息安全问题的根源主要是计算机与互联网(Internet)相连造成的。互联网具有四个特点，即国际化、社会化、开放化、个人化。互联网上的攻击不仅来自本地网络的用户，还可以来自互联网上的任何一台计算机。开放性和资源共享是网络安全问题的根源。网络技术是全开放的，任何人或团体都可能获得。随着网络应用的深入，人类的生活越来越离不开网络，人们可以自由地访问网络，自由地使用和发布各种类型的信息，但同时也面临着来自网络的安

全威胁。

此外，微机的安全结构简单化，操作系统存在安全漏洞也是产生安全问题的主要原因。我们都知道计算机的发展历史，从巨型机、大型机、中型机到小型机，再到微机，计算机的体积越来越小，计算机的结构越来越简单。微机为了降低成本，简化了结构，去掉了许多安全机制，但是今天的微机已经不再是单纯的个人计算机，而是办公室或家庭用的公用计算机了。由于微机去掉了部分安全机制，而微机的应用环境更加开放，安全防御能力就显得较弱。更何况，现在平板计算机、智能手机等设备又进一步简化了微机的结构，其安全机制就更加脆弱。另外，由于高度复杂性和多样性，操作系统都不可能做到完全正确，其安全漏洞成为黑客攻击的主要渠道。

网络的发展把计算机变成网络中的一个组成部分，在连接上突破了机房的地理隔离，信息的交互扩大到了整个网络。由于互联网缺少足够的安全设计，于是置于网络世界中的计算机便面临巨大的风险。现代企业运行会涉及不同组织的多个信息系统，系统之间的联系日益密切，造成信息系统的规模不断扩大，复杂性不断增加。现代信息技术（如 Web 技术）使系统之间的连接更加容易，但不同系统的连接会造成系统运行的不确定性和不可预见性，从而增加了系统的风险。

更为重要的是由于信息是重要的战略资源，各种计算机系统集中管理着国家和企业的政治、军事、经济等重要信息，因此计算机系统成为不法分子的主要攻击目标。当前，信息安全问题呈现以下趋势。

1. 威胁类型多样化

网络攻击、病毒、木马、恶意软件、非法钓鱼网站等威胁种类不断增加，并且具有越来越高的复杂度和隐蔽性。

2. 大规模的数据泄露事件频发

近年来，国内外各种规模的数据泄露事件频发，涉及的数据量越来越大，影响范围越来越广，给个人和企业带来了巨大的损失。

3. 对网络安全的依赖性增加

随着数字技术的发展，人们对网络的依赖性越来越高，如果网络系统受到攻击，就会造成不可预知的后果。

4. 全球网络安全合作面临挑战

由于网络安全问题的高度敏感性，并可能涉及国家安全问题，各国对网络安全的态度和政策不一，国际网络安全合作亟待加强。

5. 人力资源短缺

网络安全领域的专业人才短缺，尤其是高级人才，造成了网络安全领域专业技能人员的供需失衡。

6. 网络安全法制建设不完善

虽然我国已经出台了多项网络安全法律和政策措施，但法制建设和执法机构的标准化程度、专业化程度等方面与发达国家还存在差距。



1.2 信息安全的威胁

据国家互联网应急中心发布的“国家信息安全漏洞共享平台（China National Vulnerability Database，CNVD）周报”显示，2023 年 6 月 5 日至 6 月 11 日，国家信息安全漏洞共享平台共收集、

整理信息安全漏洞254个，其中高危漏洞175个、中危漏洞68个、低危漏洞11个。漏洞平均分值为7.24。在这一周所收录的漏洞中，涉及零日(0day)漏洞206个(占81%)，其中包括互联网上出现Tenda AC 23命令注入漏洞、Faculty Evaluation System SQL注入漏洞(CNVD-2023-45448)等零日代码攻击漏洞。这一周CNVD接到的涉及党政机关和企事业单位的漏洞总数27 201个，与前一周(12 598个)环比增加1.16倍。这些数据进一步说明信息安全威胁就在我们身边。

1.2.1 信息安全威胁存在的原因

信息安全威胁的原因分为内因和外因两方面。

1. 内因

之所以今天信息安全问题日益突出，其主要原因之一是人们认识能力和实践能力具有局限性。从计算机发展的历史来看，从科学计算到今天无所不在的计算机应用和数据处理，计算机的功能远远超出了当初发明计算机的目标。今天我们用计算机处理着各种各样的数据，包括国家、企业、个人各方面的数据。

从计算机网络的发展来看，从最初的军事通信和科学研究，到今天计算机通信网络及Internet已成为我们社会结构的一个基本组成部分。计算机网络广泛应用于社会生活的各个方面。从学校远程教育到政府日常办公乃至现在的电子社区，都离不开网络技术，网络在当今世界无处不在。计算机网络的应用也远远超出当初网络设计的想象。

随着计算机与计算机网络应用的普及、人们认识水平的不断提高，计算机与网络安全机制也在不断完善。

同时，随着计算机应用的普及和深入，软件系统的规模越来越大，也越来越复杂，以至于其复杂性超出了人们控制和理解的范围，软件中的漏洞不可避免。例如，Windows 11有超过5000万行代码，如此庞大、复杂的系统，尽管经过严格的测试，也无法避免存在一些漏洞。

此外，在计算机系统方面，不仅面临着硬件(如CPU)的安全隐患、操作系统(如Windows)的安全隐患、网络协议(如TCP/IP)的安全隐患、数据库系统(如Oracle)的安全隐患，还面对着计算机病毒的威胁。除了技术因素以外，管理疏漏也是造成信息安全问题的主要原因之一。

2. 外因

信息安全的外因主要是计算机信息系统面临着不同层次的安全威胁。国家层面的有各国专门搜集有关政治、军事、经济信息的情报机构、信息战士。例如，美国于2010年成立了网络司令部，负责“计划、协调、整合、执行任务，以指挥网络战，保护特定的国防部信息网络，执行网络全谱作战，确保美国及其盟友在网络空间的行动自由，消除对手的行动自由”。美国参谋长联席会议于2022年12月发布新版联合条令《网络空间作战》(JP 3-12)，在正式条令中对现实战术空间的网络作战进行了阐述。在现役部队和能力方面，美国陆军已经建立了第11网络营，其前身为第915网络战营，主要实施地面战术网络作战、电子战和信息作战。

除了国家安全威胁，还有恐怖分子、工业间谍、犯罪团伙及黑客等有组织的信息安全威胁。他们破坏公共秩序、制造混乱；掠夺企业竞争优势，进行恐吓；有计划地施行报复，破坏制度，实现其目的。

信息安全的防御与攻击过程，就如同战场上的防御与攻击。处于防御一方的计算机用户处于明处，面临着许多不利的条件。例如，信息安全管理体制不能满足网络发展的需要，网络安全技术远远落后于网络应用。再加上在网络系统建设过程中，往往忽视网络安全建设。用户信息安全意识薄弱，缺乏相应的信息安全知识，也是造成信息安全问题突出的一个重要

因素。

对于攻击方来说，则恰恰相反。攻击者层次不断提高，出现黑客专业化的趋势，攻击者往往掌握了深层次网络技术。攻击点越来越多，攻击代价越来越小，一人一机、安坐家中便能发起攻击。攻击手段越来越先进，任何先进的技术都是一把“双刃剑”，计算机性能大幅提升，为破译密码、口令提供了先进手段。

总之，计算机信息系统不安全的原因主要是自身缺陷、开放性、黑客攻击等。信息安全的主要威胁包括以下几方面。

（1）黑客攻击：黑客可以通过网络实施各种攻击，如DDoS攻击、SQL注入攻击、网络钓鱼攻击、木马病毒攻击等，从而窃取机密信息或破坏网络系统的正常运作。

（2）恶意软件：指恶意程序，如病毒、木马、蠕虫和间谍软件等。这些软件可以在用户不知情的情况下入侵系统，从而窃取密码、个人信息等，有些甚至会占用系统资源，导致系统崩溃。

（3）数据泄露：指机密信息被人窃取，如银行账号、密码等。这些信息一旦落入黑客手中就会对用户造成巨大的损失。

（4）人为疏忽：如使用弱密码、共享机密信息、未及时更新系统补丁等。这些都可能导致系统被黑客入侵、窃取数据，从而引发安全问题。

（5）社会工程：指一种通过网络欺骗用户，从而获得机密信息的攻击方式，如钓鱼邮件、欺诈电话等。

1.2.2 信息安全威胁的主要形式

信息安全威胁是各种可能破坏计算机和网络安全的行为。目前常见的信息安全威胁的主要形式有病毒与恶意软件、未授权访问、数据泄露、社会工程学攻击、分布式拒绝服务攻击、注入攻击、跨站脚本攻击、无线攻击、零日漏洞攻击等。

1. 病毒与恶意软件

病毒与恶意软件是最常见的计算机安全威胁之一，是攻击者用于攻击个人计算机、服务器等设备、系统或应用程序的常见工具。恶意软件包括木马、蠕虫等，它们可以通过电子邮件、下载文件、共享文件等方式传播到计算机和网络中，窃取用户敏感信息、控制计算机或服务器，破坏系统和数据的完整性和可用性。

病毒是一种专门设计用于感染计算机的恶意软件。作为一种人为的特制程序，病毒具有自我复制能力、很强的传染性、一定的潜伏性、特定的触发性、强大的破坏性等特点。它通过植入计算机系统文件中，可以在不被用户察觉的情况下进行破坏。病毒可以传播到系统的各部分，包括程序文件、文档和系统文件等。一旦病毒感染了计算机系统，它可以在不停止系统工作的情况下进行破坏，拦截网络连接或冻结操作系统等。

图1.1所示的病毒感染示意图展示了一个典型的病毒感染计算机的过程。通过下载未经验证的文件或软件，或访问受感染的网站等方式，计算机被感染了病毒。病毒都会被设定明确的触发条件，随着计算机的继续使用，当触发条件满足时，病毒会集中大规模暴发，开始侵蚀用户的系统，窃取敏感信息等，并通过移动设备与网络传染到其他计算机中。

一旦计算机被感染，随着时间的推移，攻击者可以控制受感染的计算机，并对计算机或网络进行更广泛的攻击，或利用受害者的账户、个人信息和文件进行非法活动。所以，在计算机使用过程中，使用者要时刻提高警惕，切勿轻信不明链接和软件的安装，并保持防护软件的更

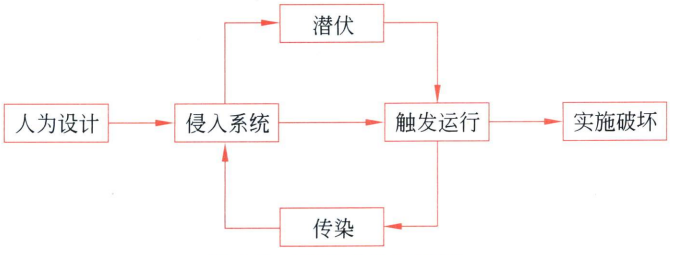


图 1.1 病毒感染示意图

新及系统的保持稳定和更新维护。

木马是常见的恶意软件，它是一种设计用于隐藏在计算机程序或文件中的恶意软件，可以通过远程控制来采集用户的敏感信息、绕过安全措施或控制被攻击计算机的文件、程序或权限等。木马并不会自我复制，而是通过用户的行为来传播和感染计算机，如通过下载、邮件附件、P2P 共享等方式传播。一旦木马被安装，它将开始执行对系统的攻击，如窃取机密信息、损坏或删除文件、拦截网络流量等，从而给用户带来严重的危害。

病毒主要是用于感染其他文件进行传播并破坏系统，而木马则是通过欺骗用户、利用漏洞等方式，在用户不知情的情况下在计算机上安装，以窃取敏感数据或控制计算机。相比而言，两者在功能、传播方式、影响程度、发现难度上有所不同，如表 1.2 所示。

表 1.2 木马与病毒对比表

对比项	木　马	病　毒
功能	盗取机密信息，维持后门，远程控制	破坏系统和文件，能够传染其他计算机
传播方式	通过下载、邮件、潜在的伪造程序等	通过感染其他文件、利用漏洞和低信任度的文件传输协议
对系统的影响	通过植入后门、窃取信息的方式对系统存储和数据安全产生影响	感染并修改、删除或冻结计算机文件及操作
发现难度	通常比较隐蔽，被安装后不易发现	由于会修改文件等可识别的特征，有一定可能会被杀毒软件检测出来

为了预防病毒和恶意软件攻击，用户需要采取一系列的安全措施。以下是一些可以有效预防病毒、恶意软件攻击的措施。

(1) 加强网络安全意识：是有效预防病毒、木马等攻击不可缺少的手段之一，通过参加网络安全类培训、定期发送安全警报或提供网络安全建议等方式，加强网络安全教育，以更好地识别和应对各种网络安全威胁。

(2) 安装杀毒软件：安装可靠的杀毒软件来扫描和清除病毒、木马等恶意软件，并保持更新版本。定期全盘扫描计算机设备并清除病毒。

(3) 谨慎下载及安装软件：只从官方或其他可靠的网站下载软件，并注意选择高评价和经过认证的软件。

(4) 及时更新软件：及时更新软件可以修补软件中的漏洞，减少遭受攻击的可能性。

(5) 强化密码安全：采用强密码，不使用相同的密码和用户名，及时更改密码等。

(6) 避免打开可疑邮件和附件：不打开可疑的电子邮件、链接或附件，避免访问未知网站；禁用可能引发安全问题的功能。

(7) 定期备份数据：妥善备份关键数据可以帮助恢复被病毒和木马破坏的数据，能够帮

助降低恶意软件攻击带来的破坏。

（8）加强计算机安全设置：为计算机设定强密码，开启防火墙，更新系统补丁，限制本地管理员账户访问等。

2. 未授权访问

未授权访问是一种常见的网络安全威胁，攻击者通过一些手段绕开应用程序或系统的身份验证和授权机制，获得对未经授权的敏感信息或功能的访问权限。它通常是由于应用程序或系统未正确限制访问权限而导致的。

攻击者可以通过多种方式利用未授权访问漏洞，如通过使用默认凭据、枚举账户、猜测密码、绕过身份验证机制、修改请求等，来获取敏感信息、执行未经授权的操作，还可能导致未授权的数据泄露。

未授权访问具有很强的危害性，攻击者可以利用受攻击系统中存在的安全漏洞或其他弱点，盗取关键的商业数据、知识产权或其他重要信息，造成个人和组织的财产损失，甚至可能对公共安全和国家安全产生威胁。

以下是几个未授权访问的具体案例。

（1）“马蜂窝”数据泄露：中国旅游平台“马蜂窝”曾在2020年被曝出存在大规模的用户数据泄露事件，涉及超过100万名用户的信息被盗，攻击者利用了未授权访问用户信息的漏洞，窃取了用户的个人资料、酒店订单、旅游路线等敏感信息。

（2）微软公司Office 365漏洞事件：2021年3月，微软Office 365曝出一系列重大安全漏洞，黑客通过该漏洞进行未授权访问，包括盗窃数据、攻击电子邮件系统等，这个事件是历史上规模最大的网络袭击之一。

（3）雅虎公司数据泄露事件：2013年，美国互联网企业雅虎公司曝出了一起规模巨大的数据泄露事件，攻击者通过未授权访问的方式盗取了约30亿账户的信息，包括姓名、电子邮件地址、电话号码、生日等个人信息。

（4）德勤数据泄露事件：2021年，全球四大会计师事务所之一的德勤事务所被曝出涉及数百万客户的数据泄露事件，攻击者利用未授权访问的漏洞访问德勤客户的电子邮件和其他敏感信息。

这些案例表明，未授权访问是一种严重的网络安全威胁，任何组织和个人都可能成为攻击者的目标，建议采取一系列有效的措施来预防未授权访问。因此，应加强信息安全意识教育，定期漏洞修补和安全扫描，并采用加密通信、多因素身份验证和访问控制措施等进行保护。如果发现了未授权访问的情况，应及时采取措施，尽可能地遏制和消除安全威胁。

3. 数据泄露

数据泄露指未经授权的人员或组织获取并泄露个人或机构的敏感信息，在计算机和网络安全中是一种严重的威胁。这种信息可能包括个人身份信息、机构机密、交易记录及银行卡信息等敏感数据。数据泄露是一种严重的网络安全威胁，可以对个人、组织或整个行业造成财务与声誉上的双重损失。数据泄露的一些常见方式如下。

（1）通过网络入侵攻击：黑客使用各种恶意软件攻击目标系统，获取系统访问权限，并从系统中窃取数据。

（2）内部人员泄露：公司内部员工或其他合法用户通过窃取数据、滥用访问权限或其他不正当的方式泄露敏感信息。

（3）云安全威胁：随着越来越多的公司将其数据存储在云存储系统中，来自第三方的攻

击和未经授权的访问都成为威胁。

(4) 第三方供应商安全问题：由于大量的公司都会使用第三方供应商的服务，这意味着泄露也可能来自于供应商的系统。

影响个人和组织的数据泄露事件往往非常严重，可能会导致以下问题。

(1) 盗取个人身份信息问题：盗取个人信息后，黑客可以利用这些信息实施身份盗窃和诱骗钓鱼等诈骗行为。

(2) 违反法规所导致的处罚问题：各国政府和组织制定有多种法律法规来保护各方数据，如果未能遵循规定，可能会面临罚款、指责和法律诉讼等后果。

(3) 业务中断问题：数据泄露可能会导致企业服务中断，影响公司正常运营。

(4) 品牌信誉受损问题：如果数据泄露事件被曝光，公司的客户可能会怀疑其安全性并对其失去信任。

因此，个人和企业都必须采取适当的安全措施以防范数据泄露，并在发生数据泄露事件时立即采取措施来追踪和处理，保护个人隐私和企业利益。

4. 社会工程学攻击

社会工程学攻击是利用心理学、社会学等相关知识，以非技术手段(如利用人的性格特质、行为规律、信息感知和交往行为等方面的弱点)获得信息、窃取财产、入侵系统等的一种攻击方式。在当今社会，社会工程学的攻击手段已越来越常见，且由于其是针对人自身的弱点进行的攻击，社会工程学攻击通常比技术攻击更容易实施，所导致的损失通常无法估算。因此，了解社会工程学攻击对保障个人和企业信息安全有着很重要的意义。

社会工程学包括心理学、社会学、人类学、计算机科学等多个基础学科。该学科最早在20世纪50年代的美国被提出，但其概念和基础研究却早在第一次世界大战时期就开始了。当时，英国被迫进行监视和谍报战争，美国也开始探索新型的军事战争方式，于是社会工程学得到了迅速发展和推广。

20世纪90年代初期，网络渗透攻击手段发展迅速，一部分黑客利用这种攻击手段入侵系统，但大部分黑客会结合社会工程学技巧，通过欺骗、假扮等方式获得权限。2000年，著名黑客Kevin Mitnick揭示了他是如何通过社会工程学和技术操作，入侵世界上最大的软件公司之一——SUN公司的网络。此后，社会工程学开始成为信息安全领域不可缺少的一部分。

社会工程学攻击通过欺骗、假扮、逼迫、攀谈、撒谎等手段，窃取信息、财物，入侵系统，主要包括网络钓鱼攻击、假冒网站攻击、垃圾邮件攻击、假冒消息攻击、诱骗攻击、猜测密码攻击等，是当前信息时代面临的主要安全威胁之一，其介绍如表1.3所示。

表1.3 社会工程学攻击对比表

攻击类型	攻击方式	目的	对抗措施
网络钓鱼攻击	发送伪装成已知机构的信息请求，诱导受害者操作	获取受害者的敏感信息	提高用户的安全意识，不轻信并辨别真假信息；使用网站证书；注意验证邮件正文中的链接；尽量使用虚拟银行账户；涉及敏感信息的网站应设立多层认证
假冒网站攻击	仿制已知网站，通过仿制网站进行欺骗操作	获取受害者的信息并进行诈骗	设置网站SSL证书、增加防钓鱼功能、DNS解析过滤等；避免在未知的网站进行数据输入；在输入重要信息或执行付款时，要检查是不是从受信任的站点转到了同样受信任的站点

续表

攻击类型	攻击方式	目　的	对抗措施
垃圾邮件攻击	发送大量垃圾邮件，企图引导受害者进入恶意链接	诱导受害者安装恶意软件或披露信息	通过启动反垃圾邮件功能、设置防病毒软件、避免单击和打开未知邮件、增加过滤邮件规则等方式防范；当出现可疑的信息或邮件，不要主动提供个人信息或资金；不要随意下载附件或单击链接，使用著名安全软件进行过滤
假冒消息攻击	利用社交工具、在线聊天窗口，冒充认识的人或机构，进行欺骗	获得受害者的敏感信息或资金汇款	增加用户对好友身份的确认、建立防窃听措施、加强信息保护等；若遭遇诈骗信息，应核实相关信息并向平台或有关部门反映；注意保护好自己的个人信息和账号密码，防止泄露
诱骗攻击	发送看起来正常的信息，在发送过程中含有恶意链接或文本信息	诱导用户访问欺诈网站/进行欺诈交易等	加强对链接的校验，慎重单击未知链接；建立防病毒软件、严格控制文件操作权等措施
猜测密码攻击	通过猜测或者暴力破解密码的方式入侵系统	获取系统中的敏感数据或掌控系统的操作权限	设置密码策略、加强口令管理、使用多因素身份认证等；对于内部人员不当操作和口令安全等方面，应加强安全意识教育和进行定期的安全演练

5. 分布式拒绝服务攻击

拒绝服务(Denial of Service，DoS)攻击指攻击者通过对目标系统发起大量的请求，耗费系统资源从而使目标系统无法正常提供服务的攻击行为。拒绝服务攻击可以导致网络拥塞、服务中断甚至系统崩溃，严重影响目标系统的稳定性和可用性。

分布式拒绝服务(Distributed Denial of Service，DDoS)加强了拒绝服务攻击的攻击威力和难度，是一种更为高级、复杂的拒绝服务攻击手段。分布式拒绝服务攻击的基本实现方法是通过多个主机向目标主机同时发出超负荷的数据流量，使其在服务请求过多的情况下不能及时处理所有的请求从而导致拒绝服务，最终使目标主机无法正常对外提供运行服务。分布式拒绝服务攻击是目前互联网领域中最常见和最危险的攻击方式之一，其攻击方式具有分布性、隐蔽性、多样性等特点，攻击强度大，防御困难，会对组织或企业造成灾难性的损失(包括服务中断、财务损失和声誉受损等)，给互联网用户正常的上网活动和网络安全带来了巨大的危害。

表1.4是拒绝服务攻击与分布式拒绝服务攻击对比表。

表1.4　拒绝服务攻击与分布式拒绝服务攻击对比表

	拒绝服务攻击	分布式拒绝服务攻击
攻击特点	由单台主机发起大量合理请求，消耗目标主机资源	由多台控制的主机发起攻击事件，攻击威力更大、更难以防御
攻击难度	低	高
攻击流量	较小	大
攻击对象	一般针对单台主机	可同时针对多台主机
攻击类型	可抵消攻击	无法抵消攻击
技巧要求	需要技术知识	需要更高的技术调用，难以发现和跟踪攻击者
防御措施	安装防火墙、入侵检测系统等	增加带宽、设置访问控制、限流等

分布式拒绝服务攻击具有以下的特点。

(1) 分布性：攻击来源广泛，不像单一来源的 DoS 攻击，攻击者会控制多台主机并将它们协调成“僵尸广播网络”。

(2) 隐蔽性：攻击者会控制大量的感染者去攻击受害者，使得攻击来源很难被识别。

(3) 多样性：DDoS 攻击手段多种多样，常见的有 IP 地址欺骗、UDP/TCP Flood 攻击、ICMP Flood 攻击、HTTP 请求攻击等，使得攻击者难以被追踪。

(4) 持续性：DDoS 攻击可以持续几小时甚至数天，从而使得目标服务器的资源被大量消耗，造成巨大的损失。

(5) 攻击威力强大：DDoS 攻击数量大、流量大，能够造成大规模的网络瘫痪和财产损失。

为了预防 DDoS 攻击，可以采取以下防范措施。

(1) 增强系统安全性：加强设备的性能和安全性，使其能够承受更多的流量攻击，并为系统设置各种必要的安全防护措施，包括安装杀毒软件、反间谍软件和防火墙等；限制一些常用协议的运行；对允许外部访问的端口、设备进行管理和限制。

(2) 基础设施防范：选用负载均衡器或流量清洗系统，通过应用层控制和硬件设备设计，清除大部分的 DDoS 攻击；进行流量分流、负载均衡，防止攻击流量集中在单一主机上；提供 DNS 解析缓存，通过自建 DNS 服务器或使用 DNS 解析服务商的负载均衡功能，提高系统抗 DDoS 攻击的能力；部署内容分发网络(Content Delivery Network，CDN)，在 CDN 节点处对流量进行初步过滤，防止攻击流量直接进入目标网站上；实施限流策略，提前控制流量，对于一些异常网络流量或者恶意软件攻击等，可以通过限制流量大小来防范。

(3) 准备备用计划：完善的备用计划可以使系统在被攻击时尽量减少损失。可提前预置备用服务器、留有备份数据等来避免数据丢失和减少系统损失。

(4) 对攻击流量进行监控和识别：通过流量和访问日志对网络行为进行监控并识别攻击流量，对目标服务的访问频率进行限制，及早发现并进行遏制，防止更多损失的发生。

6. 注入攻击

注入攻击(injection attack)指攻击者利用应用程序或系统存在的漏洞，将恶意的代码、数据或指令等通过 Web 应用程序的输入参数、其他合法的输入机制传递进去，从而让 Web 应用程序向后端执行恶意操作，甚至能够控制底层系统。注入攻击常见的类型有 SQL 注入、XPath 注入、OS 命令注入等。

作为一种常见的攻击方式，注入攻击可以让攻击者轻松绕过 Web 应用程序的认证及访问控制机制，并从底层操作系统中获取敏感数据，如用户名、密码等，使攻击者能够对应用程序进行更深入和更广泛的攻击。

在注入攻击成功的情况下，攻击者可以修改数据库中的数据，或是利用数据库的存储过程或脚本直接改变系统的核心功能逻辑，轻则影响系统性能，重则影响系统的安全甚至导致系统瘫痪。

为了防止注入攻击，开发和运维人员需要采取的一些措施如下。

(1) 数据校验与预处理：通过对参数进行合法性检查，或是使用特定的数据格式，可以减少恶意输入的可能性。

(2) 防火墙过滤：在 Web 应用程序和数据库之间设置防火墙，过滤掉非法请求。另外，也可以使用 WAF(Web 应用程序防火墙)等技术解决注入攻击问题。

(3) 减少权限：对于应用程序，不应该具备过多的权限。只有确实需要进行访问的模块

才能够被访问，其他的模块则进行限制。

（4）隐藏错误信息：在 Web 应用程序出现服务器错误时，应该隐藏错误的具体信息，仅显示简单的错误提示信息，以免被攻击者利用。

（5）使用绑定参数的预编译语句：在与数据库的交互中使用绑定参数的预编译语句，可以有效地防止 SQL 注入攻击。

7. 跨站脚本攻击

跨站脚本（Cross-Site Scripting，XSS）攻击是一种常见的 Web 应用程序安全漏洞，通常利用 Web 应用程序没有充分检查或验证用户输入的过滤方式。攻击者通过在 Web 应用程序中注入恶意脚本（代码），实现非法操作或窃取用户的敏感信息。

跨站脚本攻击可分为反射型、存储型和 DOM 型三种类型。反射型 XSS 攻击主要是通过欺骗用户来访问带有恶意脚本的链接，攻击会利用 Web 应用程序缺乏有效的输入过滤和输出转义机制，将用户提供的恶意脚本直接输出到响应页面，当用户访问了这些受感染的页面后，恶意脚本就会被执行。存储型 XSS 攻击将恶意脚本上传到服务器的数据库中，并在页面中展现给用户，当用户请求这些页面时，恶意脚本会被执行。DOM 型 XSS 攻击则是利用了浏览器的文档对象模型（Document Object Model，DOM）机制中的漏洞，通过篡改网页中的 Java Script 脚本实现攻击。

跨站脚本攻击所带来的危害十分严重，主要包括泄露用户敏感信息，进行非法操作修改或删除用户数据，导致用户暴露于隐私泄露和信息泄露等风险中。为了避免跨站脚本攻击的危害，应用程序需要加强输入过滤和输出验证，对于任何用户输入数据都进行过滤处理和特殊字符转义，从而有效地减少漏洞攻击的风险。

8. 无线攻击

无线攻击是针对无线局域网（WLAN）和蓝牙、NFC 等无线网络协议的攻击。攻击者可以利用无线协议的漏洞，对用户进行拦截、监听、控制等攻击行为，从而窃取敏感信息或掌控整个网络。无线攻击面广、攻击手段较为灵活，威胁影响比较大。

无线攻击常见类型包括网络侦听、伪造基站、中间人攻击、身份仿冒，其对比如表 1.5 所示。

表 1.5 无线攻击常见类型对比表

攻击类型	描　述	攻击目的	防御手段
网络侦听	使用无线嗅探器截获无线网络通信，监听并窃取目标数据	窃取无线网络数据，进行恶意分析，窃取网络中的敏感信息	使用加密技术保护数据传输，使用在线加密软件
伪造基站	制造虚假基站，并冒充真实基站的身份，以便控制设备或窃取用户登录信息	窃取客户机上的敏感信息进行攻击	明确无线基站身份，避免相信虚假基站
中间人攻击	入侵系统并截获数据流量，窃取用户身份和机密信息	窃取用户登录信息，监听并篡改设备和用户的通信内容	使用数据加密技术；使用 TLS/SSL，重点避开所有可疑网络
身份仿冒攻击	伪造 SSID、MAC 地址等用户认证信息，仿冒无线接入点以获取目标用户登录信息	获取用户名和密码信息等敏感信息，进行恶意攻击	避免单击未知 WiFi，不要“自动连接”开放网络

9. 零日漏洞攻击

零日漏洞攻击(zero day exploit)指攻击者利用软件或系统的未知漏洞,进行针对性攻击的行为,攻击者利用这些未公开的漏洞,可以得到比已知漏洞更高的成功概率,对目标系统进行攻击,这种攻击通常比普通攻击更难以预防和检测。

零日漏洞攻击通常是针对特定的软件、系统或目标进行的,攻击者会仔细分析目标系统并寻找未知漏洞,一旦发现漏洞,攻击者会立即展开攻击行动,通常是通过发送特制的恶意软件、代码或数据包来触发漏洞。

与已知漏洞攻击不同,零日漏洞攻击可以避开传统的漏洞检测和防御措施,给攻击者带来极大的优势。攻击者通过利用零日漏洞可以窃取用户隐私信息、破坏系统稳定性、破坏国家安全等。

为了避免零日漏洞攻击,可采用以下几个重要的防御措施。

(1) 及时升级和安装补丁:及时升级和安装软件及系统的最新版本,避免被已知漏洞攻击。

(2) 加强安全防护:采取防病毒软件、防火墙等安全防护措施,阻止未知的恶意软件攻击。

(3) 安全策略检查:加强网络安全策略,实现网络的综合防护,包括网络拓扑优化、用户权限管理等。

(4) 数据备份:对数据进行及时备份,防止数据被窃取、损坏或丢失。

(5) 漏洞扫描和入侵监测:进行漏洞扫描和安全监测,及时发现并处理系统内部的漏洞和安全缺口。

总之,由于零日漏洞攻击的攻击者利用未知漏洞的突袭方式具有危险性和隐秘性,对于安全管理员而言,需要搭建健康的防范体系,建立及时了解漏洞威胁的机制,提高安全绩效技能和技术水平,及时识别、判别、阻断和消除零日漏洞攻击的行为。

以上是一些常见的信息安全威胁的具体形式。维护信息安全是一项非常重要的工作。要想减轻安全风险和相应的损失,需要全面了解当今信息安全威胁的各种形式,并采取相应的措施,综合运用技术、管理和人员培训等多种手段来应对和防范这些威胁。

1.3 信息安全体系结构

随着信息技术的发展与应用,信息安全的内涵在不断地延伸,从最初的信息机密性发展到信息的完整性、可用性、可控性和不可否认性等,进而又发展为“攻(攻击)、防(防范)、测(检测)、控(控制)、管(管理)、评(评估)”等多方面的基础理论和实施技术。人们借助信息安全体系结构(Information Security Architecture,ISA)能够更清晰地梳理信息系统中所需安全理论和技术的相关知识及其联系、加深理解其内涵。

信息安全体系是构成信息系统的组件、环境和人(用户和管理者)的物理安全、运行安全、数据安全、内容安全、应用安全、管理安全与信息资产安全的总和,是一个多维度、多元素、多层次、时变的非线性复杂系统,其最终安全目标是控制信息系统的总风险趋于稳定,并达到最小(绝对安全的信息系统是不存在的)。相关领域的专家和学者们从不同的角度对信息安全体系结构进行了描述,归纳、分析或设计出侧重点不同的体系结构。

1.3.1 面向目标的信息安全知识体系结构

信息安全的三个最基本的目标是机密性、完整性和可用性，即CIA三元组，其概念的阐述源自信息技术安全评估标准（Information Technology Security Evaluation Criteria，ITSEC）。很多的信息安全技术是围绕CIA三元组来进行研究的。

机密性指信息存储、传输、使用过程中，不会泄露给非授权用户或实体；完整性指信息在存储、使用、传输过程中，不会被非授权用户篡改或防止授权用户对信息进行不恰当的篡改；可用性则涵盖的范围最广，凡是为了确保授权用户或实体对信息资源的正常使用不会被异常拒绝，允许其可靠而及时地访问信息资源的相关理论技术均属于可用性研究范畴。

围绕CIA三元组可以构建信息安全的知识体系结构，对所需信息安全领域的知识进行梳理，其示意图如图1.2所示。

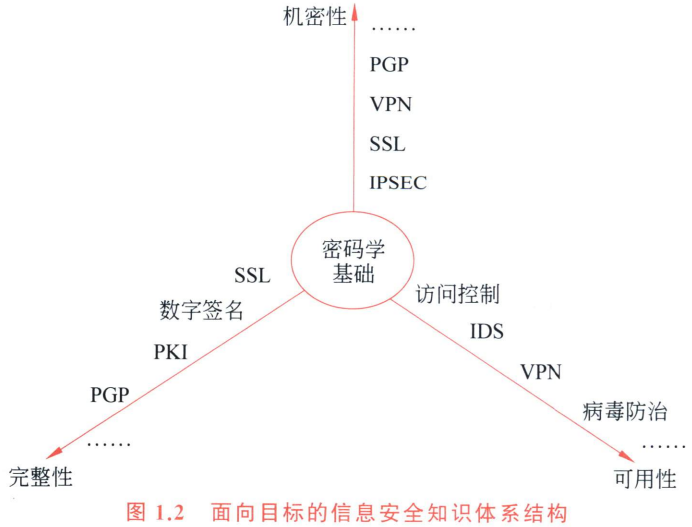


图1.2 面向目标的信息安全知识体系结构

实际上，CIA三元组在内容上存在一定程度的交叉，因此支撑和保障其实现的信息安全知识、技术之间也是相互交叉的。例如，密码学知识是实现CIA三元组的共同基础，SSL、PGP等技术能够实现完整性和机密性需求。

除了CIA三元组外，信息安全还有一些其他普遍认可的基本特征和目标，包括不可否认性（non-repudiation）、可认证性（authenticity）、可控性（controllability）、可追踪性（accountability）等，这些都是对CIA原则的细化、补充或加强。

1.3.2 面向过程的信息安全保障体系结构

“信息安全保障”这一概念最早是由美国国防部提出的，其定义为：保护和防御信息及信息系统，确保其机密性、完整性、可用性、可认证性、不可否认性等特性，包括信息系统中融入保护、检测、响应功能，并提供信息系统的恢复功能。这个定义明确了机密性、完整性、可用性、可认证性、不可否认性这五个安全属性，提出了保护（protect）、检测（detect）、响应（react）、恢复（restore）这四个动态的工作环节，强调了信息安全保障的对象不仅是信息，也包括对信息系统。这就是PDRR动态安全模型，如图1.3所示。

PDRR动态安全模型把信息的安全保护作为基础，将保护视为活动过程，要用检测手段来

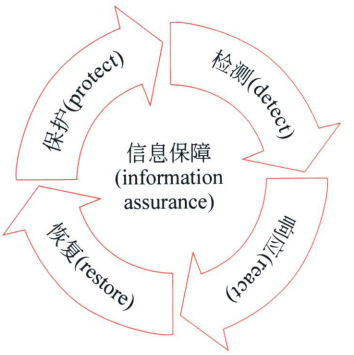


图 1.3 PDRR 动态安全模型

发现安全漏洞，及时更正；同时采用应急响应措施对付各种入侵；在系统被入侵后，要采取相应的措施将系统恢复到正常状态，这样使信息的安全得到全方位的保障。图 1.4 为 PDRR 动态安全模型动态保护信息安全的示意图。

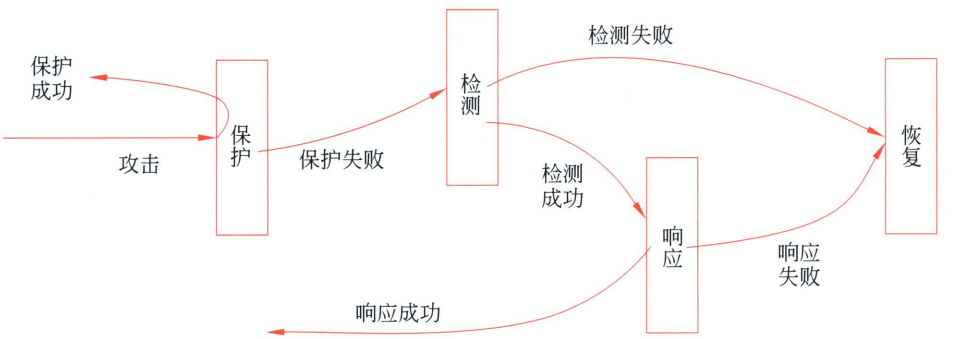


图 1.4 PDRR 动态安全模型动态保护信息安全的示意图

PDRR 动态安全模型引入了保护时间、检测时间和响应时间的概念，通过数学公式指出只要系统的检测时间加上响应时间小于系统保护时间，就可以称系统是安全的。PDRR 是最常用的动态可适应安全模型，能够为信息安全保障系统建设提供实践指导。

建设信息安全保障体系的策略是增强系统针对威胁和攻击的防御能力，我国信息安全专家组还提出在 PDRR 动态安全模型的前后增加预警(warning)和反击(counterattack)环节，即 WPDRRC 模型，以便对受保护对象提供更多层次保护。

除了 PDRR 安全保障体系外，另外一个受人们关注的体系是信息保障技术框架(Information Assurance Technical Framework，IATF)。

IATF 是由美国国家安全局组织专家编写的一个全面描述信息安全保障体系的框架，它提出了信息保障时代信息基础设施的全套安全需求。IATF 提出了信息保障依赖于人、操作和技术来共同实现组织职能、业务运作的思想，对技术、信息基础设施的管理也离不开这三个要素。人借助技术的支持，实施一系列的操作过程，最终实现信息保障目标，这就是 IATF 最核心的理念。IATF 定义了实现信息保障目标的工程过程和信息系统各方面的安全需求。在此基础上，对信息基础设施就可以做到多层防护，这样的防护被称为“纵深防御战略(defense-in-depth strategy)”，IATF 核心思想如图 1.5 所示。

IATF 综合运用人、技术和操作的因素来实现积极动态防御。不同于 WPDRRC 从安全防护层次提出安全防护模型的架构，IATF 从信息系统的构成出发提出了安全保障架构，这也

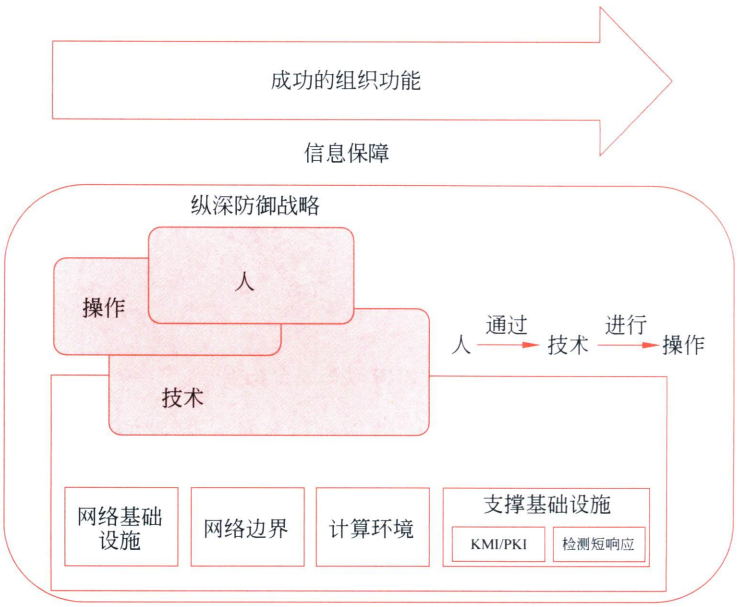


图 1.5 IATF 核心思想框架

使其成为被广泛使用的安全保障体系结构。

1.3.3 面向应用的层次信息安全体系结构

信息系统的三个基本要素为人员、信息、系统，针对三个不同组成部分存在五个安全层次，分别为针对系统部分的物理安全和运行安全，针对信息部分的内容安全和数据安全，以及针对人员部分的管理安全，如图 1.6 所示。

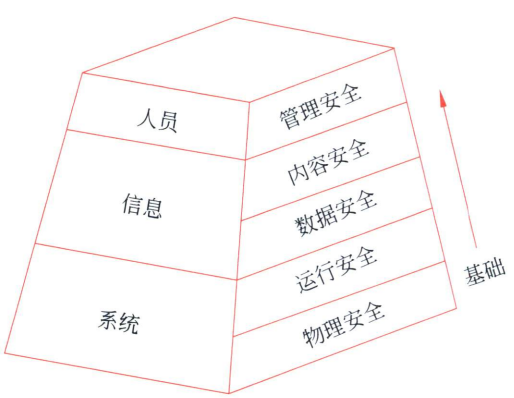


图 1.6 面向应用的层次信息安全体系结构

这五个安全层次存在着一定的顺序关系，每个层次均为其上层提供基础安全保证，没有下层的安全，上层安全无从谈起。同时，各个安全层次均依靠相应的安全技术来提供保障，这些技术从多角度全方位保证信息系统安全，如果某个层次的安全技术处理不当，各层安全性均会受到严重威胁。

物理安全是整个信息系统安全的基础，包括实体安全和环境安全，它们都用于研究如何保护网络与信息系统物理设备，主要涉及网络与信息系统的机密性、可用性、完整性等属性。物理安全技术用来解决两方面的问题，一方面是针对信息系统实体的保护；另一方面针对可能造

成信息泄露的物理问题进行防范。因此，物理安全技术包括防盗、防火、防静电、防雷击、防信息泄露及物理隔离等安全技术；另外，基于物理环境的容灾技术和物理隔离技术也属于物理安全技术范畴。物理安全是信息安全的必要前提，如果不能保证信息系统的物理安全，其他一切安全内容均没有意义。

运行安全指网络及信息系统的运行过程和运行状态的保护，主要涉及网络与信息系统的真实性、可控性、可用性等。运行安全主要安全技术包括身份认证、访问控制、防火墙、入侵检测、恶意代码防治、容侵技术、动态隔离、取证技术、安全审计、预警技术，以及操作系统安全等，其内容繁杂并且在不断地发展变化。

数据安全主要关注信息系统中存储、传输和处理过程中的数据的安全性及数据备份和恢复，避免非法冒充、窃取、篡改、抵赖现象，主要涉及信息的机密性、真实性、完整性、不可否认性等。数据安全技术主要包括认证、鉴别、完整性检验、数字签名、PKI、安全传输协议及 VPN 等技术。

内容安全主要包括两方面内容，一方面是对合法的信息内容加以安全保护，如对合法的音像制品及软件的版权保护；另一方面是针对非法信息内容实施监管，如对反动、色情、暴力信息的过滤等。内容安全的难点在于如何有效地理解信息内容，甄别其合法性，涉及的主要技术包括文本识别、图像识别、音视频识别、隐写术、数字水印及内容过滤等。

管理安全指通过对人的信息行为的规范和约束，实现对信息机密性、完整性、可用性及可控性的保护。“三分技术，七分管理”，技术是实现的手段，对人的行为的管理则是信息安全的关键所在。管理安全主要涉及的内容包括安全策略、法律法规、安全组织、安全教育等。

1.3.4 面向网络的 OSI 信息安全体系结构

目前，信息安全已经发展成为一个综合性的、复杂的交叉性学科。广义地说，信息安全体系结构是以保障组织（包括其信息系统）的工作使命为目标，而建立的一套体现安全策略的有关技术体系、组织体系和管理体系的资源集成和配置方案。

在基于网络的分布式系统或应用中，信息需要在网络中传输，因此一般面临着公用网络中的安全通信和实体认证等问题。20 世纪 80 年代，国际标准化组织（International Organization for Standardization，ISO）推出了基于开放系统互连（Open System Interconnection，OSI）参考模型中七层协议之上的信息安全体系结构。OSI 安全体系结构是一个普遍适用的安全体系结构，提供了解决开放系统互连中的安全问题的一致性方法，对网络信息安全体系结构的设计具有重要的指导意义。

为了保证异构计算机进程与进程之间远距离交换信息的安全，OSI 安全体系结构定义了五大类安全服务和对这五大类安全服务提供支持的八类安全机制，以及相应的开放式系统互连的安全管理，图 1.7 为其安全体系示意图。

1. 安全服务

安全服务（security service）是计算机网络提供的安全防护措施。国际标准化组织定义的安全服务包括以下五大类。

（1）鉴别服务：可以鉴别参与通信的对等实体和来源，授权控制的基础，提供双向的认证；一般采用密码技术来进行身份认证。

（2）访问控制：控制不同用户对信息资源访问权限，要求有审计核查功能，尽可能地提供细粒度的控制。

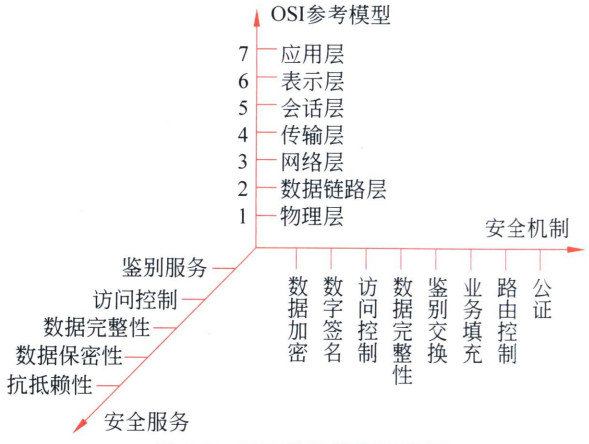


图 1.7 OSI 安全体系示意图

（3）数据完整性：指通过网上传输的数据应防止被修改、删除、插入替换或重发，以保证合法用户接收和使用该数据的真实性；用于对付主动威胁。

（4）数据保密性：提供保护，防止数据未经授权泄露；基于对称密钥和非对称密钥加密的算法。

（5）抗抵赖性：接收方要发送方保证不能否认收到的信息是发送方发出的信息，而不是被他人冒名篡改过的信息；发送方也要求对方不能否认已经收到的信息，抗抵赖性对金融信息系统很重要。

2. 安全机制

安全机制(security mechanism)是用来实施安全服务的机制。安全机制既可以是具体的、特定的，也可以是通用的。国际标准化组织定义的安全机制如下。

（1）数据加密机制：向数据和业务信息流提供保密性，对其他安全机制起补充作用。

（2）数字签名机制：对数据单元签名和验证，签名只有利用签名者的私有信息才能产生出来。

（3）访问控制机制：利用某个实体经鉴别的身份或关于该实体的信息或该实体的权限，进行确定并实施实体的访问权；可用于通信连接的任何一端或用在中间连接的任何位置。

（4）数据完整性机制：包括两方面，即单个的数据单元或字段的完整性、数据单元串或字段串的完整性。

（5）鉴别交换机制：通过信息交换以确保实体身份的机制。

（6）业务填充机制：一种制造假的通信实例、产生欺骗性数据单元或在数据单元中产生假数据的安全机制；提供对各种等级的保护，防止业务分析；只在业务填充受到保密性服务时有效。

（7）路由控制机制：路由既可以动态选择，也可以事先安排；携带某些安全标签的数据可能被安全策略禁止通过某些子网、中继站或数据链路；连接的发起者可以请求回避特定的子网、中继站或数据链路。

（8）公证机制：关于在两个或三个实体之间进行通信的数据的性能，可由公证机制来保证；保证由第三方提供；第三方要得到通信实体的信任。

表 1.6 给出了 OSI 信息安全体系结构中安全服务与安全机制之间的对应关系，描述了各安全机制所能实现的安全服务。例如，加密机制可以用于实现鉴别服务、数据保密性服务与数据完整性等服务，而鉴别交换安全机制只能用于鉴别服务中对等实体的鉴别。

表 1.6　OSI 安全服务与安全机制之间的对应关系

安全服务		安全机制							
		数据加密	数字签名	访问控制	数据完整性	鉴别交换	业务填充	路由控制	公证
鉴别服务	对等实体鉴别	Y	Y			Y			
	数据源鉴别	Y	Y						
访问控制	访问控制服务			Y					
数据保密性	连接保密性	Y						Y	
	无连接保密性	Y						Y	
	选择字段保密性	Y							
	流量保密性	Y					Y	Y	
数据完整性	有恢复功能的连接完整性	Y			Y				
	无恢复功能的连接完整性	Y			Y				
	选择字段的连接完整性	Y			Y				
	无连接完整性	Y	Y		Y				
	选择字段非连接完整性	Y	Y		Y				
抗抵赖性	发送方抗抵赖性		Y		Y				Y
	接收方抗抵赖性		Y		Y				Y

注：Y 为拥有该机制。

表 1.7 给出了 OSI 信息安全体系中安全服务与七层网络协议之间的配置关系，以实现网络数据传输的安全需求。在 OSI 七层协议中，理论上除了会话层外，其他层均可配置相应的安全服务。但是，最适合配置安全服务的是物理层、网络层、传输层及应用层，其他层一般不适合配置安全服务。

表 1.7　安全服务与 OSI 各协议层之间的配置关系

安全服务		OSI 协议层						
五大类		物理	数据链路	网络	传输	会话	表示	应用
鉴别服务	对等实体鉴别			Y	Y			Y
	数据源鉴别			Y	Y			Y
访问控制	访问控制服务			Y	Y			Y
数据保密性	连接保密性	Y	Y	Y	Y		Y	Y
	无连接保密性		Y	Y	Y		Y	Y
	选择字段保密性							
	流量保密性						Y	Y

续表

安全服务		OSI协议层						
数据完整性	有恢复功能的连接机密性	Y		Y				Y
	无恢复功能的连接机密性				Y			Y
	选择字段连接完整性			Y	Y			Y
	无连接完整性							Y
	选择字段非连接完整性			Y	Y			Y
抗抵赖性	发送方抗抵赖性							Y
	接收方抗抵赖性							Y

注：Y为拥有该协议层。

1.4 本章小结

“没有网络安全就没有国家安全”已经成为我国战略。党的二十大报告将国家安全作为独立部分进行全面和系统的阐述，涵盖政治、军事、国土、经济、文化、社会、科技、网络、生态、资源等诸多领域。因此，要站在国家安全的高度，学习和研究网络安全、信息安全的理论与技术。本章系统介绍了信息安全的基本概念，分析了信息安全威胁存在的主要原因，指出了信息安全威胁的主要形式，最后从不同角度介绍了信息安全的体系结构，为学习信息安全相关理论与技术奠定了基础。



思 考 题

1. 简述信息安全体系的三个最基本的目标。

2. 信息安全PDRR模型包括哪些环节？每个工作环节的具体含义是什么？

3. 信息系统有哪三个基本组成部分？在面向应用的层次型信息安全技术体系中，针对每个部分具有哪些安全层次？

4. OSI安全体系结构中定义了哪些安全服务和安全机制？

5.《中华人民共和国网络安全法》对关键信息基础设施的运行安全是如何描述的？